

Security+ 3.1 · Cloud Infrastructures

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 3.1 — Cloud Infrastructures (9:56)**

· [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Nuvem: IaaS (EC2 — tu cuida do SO pra cima); PaaS (Heroku/AWS Beanstalk — plataforma pronta); SaaS (Gmail — tudo pronto). Serverless/FaaS (Lambda: código sobe na chamada, paga por execução). IaC (Infrastructure as Code — Terraform, CloudFormation — infra VERSÃO-EDITÁVEL). Defesa: IAM, SG (security group), VPC.

💡 Highlights que a prova cobra

- IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider
- Serverless (Lambda): sem servidor — paga execução
- IaC (Terraform): infra como código — versionada audível

🎯 Dicas de prova & Cenários Típicos

- 'cloud model where user manages the OS and above' = IaaS
- "runs code without managing servers" = serverless/FaaS

Cenário clássico de exame: Cenário: 'empresa aluga máquinas virtuais e gerencia o sistema operacional' — IaaS.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 3.1 — Cloud Infrastructures)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **SAAS:** Software as a Service: Modelo de nuvem onde o provedor gerencia toda a infraestrutura e aplicação (ex: Salesforce, Microsoft 365, Google Workspace).
- **PAAS:** Platform as a Service: Modelo de nuvem onde o provedor fornece o ambiente de execução e banco de dados, cabendo ao cliente desenvolver e manter a aplicação.
- **IAAS:** Infrastructure as a Service: Modelo de nuvem onde o provedor fornece poder computacional básico (VMs, rede, storage) e o cliente administra o SO e softwares.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Você aluga só a máquina virtual e gerencia o SO e tudo acima. Que modelo é?

- A)** SaaS
- B)** PaaS
- C)** IaaS
- D)** On-premises

2. Gmail, Office 365 e Salesforce são exemplos de qual modelo?

- A)** IaaS
- B)** PaaS
- C)** SaaS
- D)** FaaS

3. Qual modelo de serviço de nuvem oferece maior controle sobre a infraestrutura, incluindo sistema operacional e middleware?

- A)** SaaS
- B)** PaaS
- C)** IaaS
- D)** FaaS

4. Qual serviço AWS permite executar código sem provisionar servidores?

- A)** EC2
- B)** ECS
- C)** Lambda
- D)** Elastic Beanstalk

5. No modelo de RESPONSABILIDADE COMPARTILHADA, quem cuida da segurança FÍSICA do datacenter?

- A)** O cliente
- B)** O provedor de nuvem
- C)** Os dois igualmente
- D)** Um auditor externo

6. Cenário corporativo (Cloud Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Cloud Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'Serverless (Lambda): sem servidor — paga execução'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Serverless (Lambda): sem servidor — paga execução...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Cloud Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'IaC (Terraform): infra como código — versionada audível'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: IaC (Terraform): infra como código — versionada audível...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Cloud Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: "cloud model where user manages the OS and above" = IaaS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'cloud model where user manages the OS and above' = IaaS...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Cloud Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'runs code without managing servers' = serverless/FaaS. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'runs code without managing servers' = serverless/FaaS...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) C — IaaS.

✓ **Por que está certa:** IaaS (Infrastructure as a Service) é o modelo de computação em nuvem em que o provedor oferece recursos de infraestrutura virtualizados, como máquinas virtuais, armazenamento, redes e firewalls, enquanto o cliente gerencia o sistema operacional, middleware, runtime, aplicações e dados. No enunciado, o cliente aluga apenas a máquina virtual e gerencia o SO e tudo acima, o que corresponde exatamente à divisão de responsabilidades do IaaS conforme definido pelo NIST SP 800-145 e pelo syllabus da CompTIA Security+ (domínio 3.1 – Arquitetura e Design de Segurança).

✗ **Por que as outras estão erradas:**

- **SaaS:** SaaS (Software as a Service) é o modelo em que o provedor entrega aplicações completas prontas para uso, gerenciando toda a pilha de infraestrutura, sistema operacional, middleware e a própria aplicação. O cliente apenas acessa o software via interface web ou API, sem gerenciar SO ou qualquer camada inferior. No cenário descrito, o cliente gerencia o SO e tudo acima, o que é incompatível com SaaS, onde essa responsabilidade é do provedor.
- **PaaS:** PaaS (Platform as a Service) oferece um ambiente de desenvolvimento e execução gerenciado, incluindo sistema operacional, runtime, middleware e serviços de banco de dados. O cliente gerencia apenas as aplicações e os dados, não o SO. No enunciado, o cliente gerencia o SO e tudo acima, o que excede o escopo de responsabilidade do cliente em PaaS. Portanto, não é o modelo correto.
- **On-premises:** On-premises (ou on-prem) refere-se à infraestrutura de TI instalada e mantida fisicamente nas dependências da própria organização, sem envolvimento de nuvem. O cliente gerencia tudo, desde o hardware até as aplicações, e não há aluguel de máquina virtual de um provedor externo. O enunciado descreve explicitamente o aluguel de uma máquina virtual, o que caracteriza um modelo de nuvem, não on-premises.

2) C — SaaS.

✓ **Por que está certa:** SaaS (Software as a Service) é o modelo de computação em nuvem em que o provedor entrega aplicações completas e prontas para uso, acessadas tipicamente via navegador ou API, com toda a infraestrutura, sistema operacional, middleware e aplicação gerenciados pelo fornecedor. Gmail, Office 365 e Salesforce são exemplos clássicos de SaaS, pois os usuários apenas utilizam o software sem se preocupar com servidores, atualizações ou manutenção. A questão pede exemplos desse modelo, e todos os três se encaixam perfeitamente na definição do NIST e no syllabus da CompTIA Security+.

✗ **Por que as outras estão erradas:**

- **IaaS:** IaaS (Infrastructure as a Service) fornece recursos de infraestrutura virtualizados, como máquinas virtuais, armazenamento e redes, sobre os quais o cliente instala e gerencia seu próprio sistema operacional e aplicações. Gmail, Office 365 e Salesforce não são infraestrutura bruta; são aplicações completas entregues como serviço. Portanto, não se enquadram em IaaS, onde o cliente teria controle sobre o SO e camadas inferiores.
- **PaaS:** PaaS (Platform as a Service) oferece uma plataforma gerenciada para desenvolvimento e execução de aplicações, incluindo SO, runtime e middleware, mas o cliente ainda é responsável por desenvolver ou implantar suas próprias aplicações. Gmail, Office 365 e Salesforce são softwares finais prontos para o usuário, não plataformas para desenvolvimento. Assim, não são exemplos de PaaS, mas sim de SaaS.
- **FaaS:** FaaS (Function as a Service) é um modelo de computação serverless em que o cliente implanta funções individuais que são executadas sob demanda em resposta a eventos, sem

gerenciar servidores ou contêineres. Exemplos incluem AWS Lambda, Azure Functions e Google Cloud Functions. Gmail, Office 365 e Salesforce não são funções serverless, mas aplicações SaaS completas. Portanto, FaaS não é o modelo correto para os exemplos citados.

3) C — IaaS.

✓ **Por que está certa:** A alternativa correta é IaaS (Infrastructure as a Service). No modelo IaaS, o provedor de nuvem entrega recursos fundamentais de computação — máquinas virtuais, armazenamento em bloco, redes virtuais e firewalls —, mas o cliente mantém o controle sobre a pilha que vai do sistema operacional convidado para cima. Isso significa que o cliente é responsável por instalar e aplicar patches no SO, configurar middleware (servidores de aplicação, bancos de dados, runtimes), gerenciar identidades e políticas de acesso, além de proteger os dados. Esse é o modelo que oferece o maior grau de controle sobre a infraestrutura entre as opções apresentadas, pois o cliente pode escolher a distribuição Linux, a versão do kernel, o servidor web, a JVM, etc. A CompTIA classifica IaaS como o modelo de serviço em nuvem que fornece controle sobre a infraestrutura subjacente, incluindo SO e middleware, enquanto o provedor gerencia a virtualização, os servidores físicos, o armazenamento e a rede física.

✗ **Por que as outras estão erradas:**

- **SaaS:** SaaS (Software as a Service) é o modelo em que o provedor entrega uma aplicação completa e pronta para uso, como Microsoft 365, Salesforce ou Google Workspace. O cliente não gerencia absolutamente nada da pilha: não tem acesso ao sistema operacional, ao middleware, ao runtime, ao banco de dados nem à infraestrutura. Toda a responsabilidade operacional e de segurança da aplicação até a camada física é do provedor. Portanto, SaaS oferece o menor controle sobre a infraestrutura, e não o maior. É o oposto do que o enunciado pede.
- **PaaS:** PaaS (Platform as a Service) fornece um ambiente gerenciado para desenvolvimento e execução de aplicações, incluindo sistema operacional, runtime, middleware e serviços de banco de dados já configurados e mantidos pelo provedor. O cliente controla apenas a aplicação e, em alguns casos, configurações limitadas do ambiente. Embora ofereça mais controle que SaaS, o cliente não gerencia o sistema operacional nem o middleware — exatamente os elementos citados no enunciado. Logo, PaaS não atende ao requisito de maior controle sobre SO e middleware.
- **FaaS:** FaaS (Function as a Service) é um modelo de computação serverless em que o cliente escreve funções individuais e o provedor gerencia totalmente a infraestrutura, o sistema operacional, o runtime e o escalonamento. O controle do cliente se limita ao código da função e a algumas configurações de gatilho e memória. Não há acesso ao sistema operacional nem ao middleware, o que torna FaaS o modelo com o menor nível de controle sobre a infraestrutura, e não o maior.

4) C — Lambda.

✓ **Por que está certa:** A alternativa correta é Lambda. O AWS Lambda é o serviço de computação serverless da Amazon, no qual o cliente fornece apenas o código (função) e define um gatilho (evento). A AWS provisiona, escala e gerencia automaticamente toda a infraestrutura subjacente — servidores, sistema operacional, runtime e capacidade — sem que o usuário precise criar ou administrar instâncias. O modelo de cobrança é por invocação e tempo de execução, e não por servidor ligado. Por isso, Lambda é a resposta exata para 'executar código sem provisionar servidores', conforme o conceito de serverless/FaaS cobrado no syllabus da CompTIA Security+.

✗ **Por que as outras estão erradas:**

- **EC2:** EC2 (Elastic Compute Cloud) é o serviço de máquinas virtuais da AWS. O cliente provisiona instâncias, escolhe o tipo, a AMI, o sistema operacional, configura rede, armazenamento e é responsável por patches e gerenciamento do SO convidado. Exige provisionamento e administração de servidores (mesmo que virtuais), portanto não atende ao requisito de executar

código sem provisionar servidores.

- **ECS:** ECS (Elastic Container Service) é um serviço de orquestração de contêineres. Embora possa ser usado com o modo Fargate (serverless), o ECS em si exige que o cliente defina clusters, tarefas, serviços e, no modo EC2, gerencie as instâncias subjacentes. Não é um serviço puramente serverless por definição; o cliente ainda precisa provisionar e gerenciar a capacidade computacional (seja via instâncias EC2 ou tarefas Fargate, que exigem configuração de CPU/memória). Portanto, não é a resposta mais direta para 'executar código sem provisionar servidores'.
- **Elastic Beanstalk:** Elastic Beanstalk é uma plataforma PaaS que automatiza o provisionamento e a implantação de aplicações, mas por baixo dos panos ele cria e gerencia recursos como instâncias EC2, load balancers e auto scaling groups. O cliente ainda precisa escolher tipo de instância, ambiente e configurações, e a aplicação roda em servidores provisionados (embora gerenciados). Não é um modelo serverless puro; há provisionamento de servidores, ainda que automatizado.

5) B — O provedor de nuvem.

✓ **Por que está certa:** No modelo de responsabilidade compartilhada da computação em nuvem, a segurança física do datacenter — incluindo controle de acesso às instalações, vigilância por vídeo, energia redundante, climatização, prevenção e combate a incêndios, e proteção contra desastres naturais — é responsabilidade exclusiva do provedor de nuvem. A CompTIA Security+ SY0-701 enfatiza que o provedor é sempre responsável pela 'segurança DA nuvem' (a infraestrutura subjacente), enquanto o cliente é responsável pela 'segurança NA nuvem' (seus dados, configurações, identidades e aplicações). O cliente não tem acesso físico ao datacenter e, portanto, não pode implementar controles físicos; a responsabilidade é intransferível e não compartilhada nesse aspecto específico.

✗ Por que as outras estão erradas:

- **O cliente:** O cliente é responsável pela segurança NA nuvem, ou seja, por seus dados, configurações de acesso, criptografia de suas informações, gestão de identidades e patches em suas instâncias. Contudo, ele não possui acesso físico ao datacenter do provedor, não pode instalar fechaduras, câmeras ou sistemas de supressão de incêndio. Atribuir a segurança física ao cliente violaria o modelo de responsabilidade compartilhada, pois este não detém o controle do ambiente físico. A questão pergunta especificamente sobre a segurança FÍSICA do datacenter, que é domínio exclusivo do provedor.
- **Os dois igualmente:** A responsabilidade compartilhada não é dividida igualmente em todos os aspectos. Ela é segmentada por camadas: o provedor cuida da segurança física, da infraestrutura de virtualização e da rede subjacente; o cliente cuida da segurança de seus dados, aplicações e identidades. A segurança física do datacenter é uma camada que o cliente não pode operar nem auditar diretamente, logo não há compartilhamento igualitário. Dizer que ambos são igualmente responsáveis pela segurança física é tecnicamente incorreto e contraria o modelo definido pela CompTIA e pelos principais provedores de nuvem (AWS, Azure, GCP).
- **Um auditor externo:** Um auditor externo realiza avaliações independentes de conformidade, como certificações SOC 2, ISO 27001 ou PCI DSS, mas não executa a segurança física do datacenter. Ele verifica se os controles implementados pelo provedor estão adequados, porém não é responsável por operá-los. A auditoria é uma função de verificação, não de operação. Portanto, atribuir a segurança física a um auditor externo confunde o papel de fiscalização com o de execução, o que é um erro conceitual grave no contexto do modelo de responsabilidade compartilhada.

6) B — Implementar a solução correspondente: IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701)

para a aula 3.1 (Cloud Infrastructures): IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: Serverless (Lambda): sem servidor — paga execução....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Cloud Infrastructures): Serverless (Lambda): sem servidor — paga execução.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: IaC (Terraform): infra como código — versionada audível....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Cloud Infrastructures): IaC (Terraform): infra como código — versionada audível.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'cloud model where user manages the OS and above' = IaaS....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Cloud Infrastructures): 'cloud model where user manages the OS and above' = IaaS.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: 'runs code without managing servers' = serverless/FaaS....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Cloud Infrastructures): 'runs code without managing servers' = serverless/FaaS.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.